

SECTION 1: PURPOSE AND SCOPE

This policy establishes the requirements for ensuring that ACME Corporation can maintain or rapidly resume critical business operations following a disruptive event. It applies to all business units, IT systems, and third-party service providers that support critical ACME operations. Disruptive events covered include natural disasters, cyberattacks, infrastructure failures, pandemics, and supply chain disruptions.

SECTION 2: RECOVERY OBJECTIVES

Each critical system and business process must have a defined Recovery Time Objective (RTO) and Recovery Point Objective (RPO) approved by the system owner and the CTO.

Tier 1 systems (mission-critical: payment processing, authentication, core APIs):
RTO must not exceed 1 hour. RPO must not exceed 15 minutes. Tier 1 systems must use active-active or active-passive redundancy with automated failover.

Tier 2 systems (business-critical: CRM, HR systems, internal communication tools):
RTO must not exceed 4 hours. RPO must not exceed 1 hour. Tier 2 systems must replicate to a secondary region with a tested failover procedure.

Tier 3 systems (important but non-critical: reporting dashboards, development tools):
RTO must not exceed 24 hours. RPO must not exceed 4 hours. Tier 3 systems may use daily backups with manual restoration procedures.

SECTION 3: BACKUP REQUIREMENTS

All production data must be backed up daily at minimum. Tier 1 system data must be replicated continuously to a geographically separate data center or cloud region. Backups must be encrypted at rest using AES-256 and in transit using TLS 1.2 or higher. Backup encryption keys must be stored separately from the backup data and must not be accessible from the primary environment in the event of a ransomware attack.

Backup restoration must be tested at least quarterly for Tier 1 systems, semi-annually for Tier 2 systems, and annually for Tier 3 systems. Restoration test results, including the time taken to restore and any errors encountered, must be documented and retained for 3 years. Failed restoration tests must be escalated to the CTO within 24 hours and remediated before the next scheduled production backup cycle.

All backups must be retained according to the following schedule: daily backups for 30 days, weekly backups for 12 months, monthly backups for 7 years. Backups subject to a legal hold must not be deleted regardless of retention schedule.

SECTION 4: BUSINESS CONTINUITY PLANS

Each department head is responsible for maintaining a Business Continuity Plan (BCP) for their department. BCPs must be reviewed and updated annually or following any significant change to business operations or critical systems. BCPs must identify: critical processes that must be maintained during a disruption; manual workarounds for automated processes; key personnel and alternates for each critical role; contact information for critical vendors and customers; and escalation procedures.

The minimum staffing required to maintain critical operations during a disruption is defined as the Minimum Business Continuity Objective (MBCO). Department heads must identify which roles constitute the MBCO and ensure cross-training so that no single

person is the sole owner of a critical process.

SECTION 5: DISASTER RECOVERY PROCEDURES

Upon declaration of a disaster or major business disruption, the Crisis Management Team (CMT) is activated. The CMT is chaired by the CEO and includes the CTO, CISO, CFO, Head of Legal, and Head of Communications. The CMT has authority to invoke the Disaster Recovery Plan, authorize emergency expenditure, and communicate with regulators.

The Incident Commander (appointed by the CISO for cyber incidents, or the CTO for infrastructure incidents) coordinates technical recovery activities and provides status updates to the CMT every 30 minutes during an active disaster.

Failover to the disaster recovery environment must be authorized by the CTO or a designated alternate. Failback to the primary environment requires a stability period of at least 4 hours after the root cause has been resolved and a sign-off from both the CTO and the system owner.

SECTION 6: TESTING AND EXERCISES

A full Business Continuity and Disaster Recovery tabletop exercise must be conducted annually, involving the CMT and all department heads. At least one live failover test for all Tier 1 systems must be conducted annually in a pre-announced maintenance window. A surprise or unannounced DR test must be conducted for at least one critical system each year. All tests must produce a written after-action report with findings and remediation timelines. Critical findings must be remediated within 30 days.

SECTION 7: VENDOR AND THIRD-PARTY DEPENDENCIES

All third-party vendors classified as critical (those whose unavailability would trigger an RTO breach for any Tier 1 or Tier 2 system) must provide evidence of their own business continuity and disaster recovery capabilities annually. Evidence may include SOC 2 Type II reports, independent audit results, or the vendor's own BCP documentation. Contracts with critical vendors must include SLAs aligned with ACME's RTO and RPO requirements and must specify the vendor's notification obligations in the event of a service disruption.

SECTION 8: COMPLIANCE AND ENFORCEMENT

Failure to maintain an up-to-date BCP, failure to test backups within the required schedule, or failure to remediate critical DR test findings within 30 days will be escalated to the relevant department head's manager and reported to the CTO and Board Audit Committee. Business continuity compliance is audited annually by the internal audit team.